PENETRATION TEST REPORT

AYISHA MINHA

1. Engagement Overview

Target System	Linux-based Web Server
Target IP	172.20.10.2
Assessment Environment	Controlled Internal Network
Classification	Confidential
Prepared For	Academic Evaluation
Report Date	April 2026
Engagement Type	Black Box

2. Confidentiality Notice

This report contains sensitive security information intended solely for academic evaluation. Unauthorized access, disclosure, or distribution of this document, in whole or in part, is strictly prohibited.

The information presented herein is based on observations and testing conducted during a controlled assessment of the target system. The findings and recommendations reflect the security posture of the system at the time of testing and may not remain valid as configurations or conditions change.

This report does not constitute a guarantee of continued security. Ongoing monitoring, regular assessments, and timely remediation of identified vulnerabilities are essential to maintain an adequate security posture.

3. Executive Summary

This report presents the findings of a penetration testing assessment conducted against a target system within an internal lab environment. The assessment was performed during April 2026 and focused on identifying vulnerabilities across network services, web applications, and system configurations.
The objective of this engagement was to identify security weaknesses, demonstrate how they can be exploited, and assess the overall impact of a multi-stage attack.

3.1 Overall Risk Rating

Critical	High	Medium	Low	Info	Total
5	3	0	0	0	8

3.2 Key Findings Summary

The assessment identified multiple vulnerabilities across the target system. The most critical findings included:

- Anonymous FTP access enabling unauthorized file retrieval
- Exposure of sensitive data through SMB shares
- Weak credentials allowing successful brute-force attack on a valid user account
- Discovery of hidden web directories through directory enumeration
- Unauthorized administrative access to the web application
- Arbitrary code execution via malicious plugin upload
- Remote code execution achieved using a publicly available exploit identified via ExploitDB and executed using Metasploit

3.3 Recommendations Overview

Immediate remediation is required for critical and high-risk vulnerabilities, particularly those enabling unauthorized access and remote code execution. Anonymous services should be disabled, and strong authentication mechanisms must be enforced.
Web application security controls should be strengthened, including restricting administrative access and preventing unauthorized file uploads. Additionally, all services should be properly configured and regularly updated.
A follow-up assessment is recommended after remediation to validate that all vulnerabilities have been effectively addressed.

4. Scope and Methodology

4.1 Engagement Scope

Target / IP Range	Description	In Scope
172.20.10.2	Internal Linux-based web application server	Yes
172.20.10.0/24	Internal lab network segment	Yes
Web Application	WordPress instance and phpMyAdmin interface	Yes

4.2 Testing Methodology

The penetration testing assessment followed a structured methodology aligned with industry practices such as the Penetration Testing Execution Standard (PTES) and the OWASP Testing Guide. The engagement was conducted in a systematic manner to identify and evaluate security vulnerabilities within the target environment.
The testing process included multiple phases, starting with reconnaissance and scanning, followed by enumeration, exploitation, and post-exploitation activities. Both automated tools and manual techniques were used to accurately identify vulnerabilities and validate their impact.

#	Phase	Activities
1	**Reconnaissance**	Network discovery using ARP scanning to identify active hosts
2	**Scanning & Enumeration**	Port scanning (Nmap), service enumeration, FTP/SMB/HTTP analysis
3	**Vulnerability Analysis**	Identification of misconfigurations, weak credentials, and exposed services
4	**Exploitation**	Brute-force attacks (Hydra), WordPress compromise, plugin upload, exploit execution (ExploitDB + Metasploit)
5	**Post-Exploitation**	Meterpreter session handling, privilege escalation, system enumeration
6	**Data Access & Validation**	Access to sensitive files, credential extraction, database access via phpMyAdmin
7	**Reporting**	Documentation of findings, risk assessment, and remediation recommendations

4.3 Tools Used

Tool	Category	Purpose
arp-scan	Reconnaissance	Network discovery and host identification
Nmap	Scanning	Port scanning and service enumeration
FTP	Enumeration	Anonymous access testing and file retrieval
SMBClient	Enumeration	SMB share access and file extraction
DirBuster	Web Enumeration	Directory and path discovery
WPScan	Web Enumeration	WordPress user and vulnerability enumeration
Hydra	Credential Attacks	Brute-force password attack
ExploitDB (searchsploit)	Vulnerability Research	Identification of publicly available exploits
Metasploit (msfconsole)	Exploitation	Execution of exploit and session creation
Meterpreter	Post-Exploitation	Remote shell access and system control
phpMyAdmin	Post-Exploitation	Database access and data extraction
Web Browser	Web Interaction	Accessing WordPress admin panel and phpMyAdmin
Linux CLI Tools	Post-Exploitation	System enumeration and file analysis (e.g., /etc/passwd)
Kali Linux	Platform	Penetration testing environment

5. Findings Summary

#	Finding Title	Severity	CVSS	Affected Host	Status
F-001	Anonymous FTP Access	**HIGH**	7.5	172.20.10.2	Open
F-002	SMB Share Exposure	**HIGH**	7.0	172.20.10.2	Open
F-003	Weak Credentials Compromise	**CRITICAL**	9.0	172.20.10.2	Open
F-004	WordPress Admin Access	**CRITICAL**	9.0	172.20.10.2	Open
F-005	Code Execution via Plugin Upload	**CRITICAL**	9.5	172.20.10.2	Open
F-006	Remote Code Execution (Public Exploit)	**CRITICAL**	10.0	172.20.10.2	Open
F-007	Privilege Escalation to Root	**CRITICAL**	10.0	172.20.10.2	Open
F-008	Database Access via phpMyAdmin	**HIGH**	7.5	172.20.10.2	Open

6. Detailed Findings

Finding F-001: Anonymous FTP Access

Severity	HIGH	CVSS Score	7.5
Affected Host	172.20.10.2		
Port / Service	21/tcp — FTP		

Description

The FTP service was configured to allow anonymous login without authentication. This misconfiguration enabled unauthorized users to access files stored on the server. During enumeration, multiple files were discovered which could assist further stages of the attack.

Risk / Business Impact

Anonymous FTP access may result in unauthorized disclosure of sensitive information. Exposed files can provide attackers with valuable data such as configuration details or user-related information, facilitating further exploitation.

Proof of Concept / Evidence

An anonymous login to the FTP service was successfully established without requiring valid credentials. Accessible files were listed and retrieved, confirming unauthorized access to the system.

Remediation

- Disable anonymous FTP access
- Restrict access to authenticated users only
- Enable logging and monitoring of FTP activity

Finding F-002: SMB Share Exposure

Severity	HIGH	CVSS Score	7.0
Affected Host	172.20.10.2		
Port / Service	139/445 — SMB		

Description

SMB shares were accessible with insufficient access controls. Multiple shares were identified and accessed, exposing internal files including configuration and backup data.

Risk / Business Impact

Exposed SMB shares may lead to leakage of sensitive organizational data. Such access can assist attackers in further reconnaissance, credential discovery, and potential lateral movement within the environment.

Proof of Concept / Evidence

Available SMB shares were enumerated and accessed successfully. Files within these shares were retrieved, confirming that sensitive information was exposed without proper restrictions.

Remediation

- Restrict SMB access using authentication
- Disable unnecessary shares
- Implement least privilege access control

Finding F-003: Weak Credentials Leading to Account Compromise

Severity	CRITICAL	CVSS Score	9.0
Affected Host	172.20.10.2		
Port / Service	FTP / Web Authentication		

Description

Weak user credentials were identified through a brute-force attack, resulting in compromise of a valid user account. The lack of password complexity and absence of account lockout controls contributed to successful credential discovery.

Risk / Business Impact

Weak authentication mechanisms significantly increase the risk of unauthorized access. Compromised credentials may be reused across multiple services, enabling attackers to escalate access and move deeper into the system.

Proof of Concept / Evidence

A password brute-force attack successfully identified valid credentials for the user account. These credentials were then used to authenticate successfully to system services.

Remediation

- Enforce strong password policies
- Implement account lockout mechanisms
- Enable multi-factor authentication

Finding F-004: WordPress Administrative Access Compromise

Severity	CRITICAL	CVSS Score	9.0
Affected Host	172.20.10.2		
Port / Service	12380/tcp — HTTP (WordPress)		

Description

Administrative access to the WordPress application was obtained using compromised user credentials. The application lacked additional authentication controls to prevent unauthorized access.

Risk / Business Impact

Administrative access provides full control over the web application, allowing an attacker to modify content, manage users, and introduce malicious components for further exploitation.

Proof of Concept / Evidence

Successful authentication to the WordPress administrative interface was achieved using compromised credentials, granting full administrative privileges over the application.

Remediation

- Restrict administrative access to trusted users
- Enable multi-factor authentication for admin accounts
- Implement login monitoring and rate limiting

Finding F-005: Arbitrary Code Execution via Malicious Plugin Upload

Severity	CRITICAL	CVSS Score	9.5
Affected Host	172.20.10.2		
Port / Service	HTTP — WordPress		

Description

The WordPress application allowed installation of plugins without sufficient validation controls. This enabled the upload and execution of a malicious plugin containing arbitrary code.

Risk / Business Impact

This vulnerability allows an attacker to execute arbitrary commands on the server, leading to full compromise of the web application and underlying system.

Proof of Concept / Evidence

A malicious plugin containing executable code was uploaded via the WordPress administrative interface. Upon execution, it resulted in successful command execution and initial access to the target system.

Remediation

- Restrict plugin installation permissions
- Validate and sanitize uploaded files
- Disable plugin uploads in production environments where not required

Finding F-006: Remote Code Execution via Public Exploit

Severity	CRITICAL	CVSS Score	10.0
Affected Host	172.20.10.2		
Port / Service	Multiple (Web Application / Exploited Service)		

Description

A publicly available exploit was identified through ExploitDB and successfully executed using the Metasploit Framework

Risk / Business Impact

Successful exploitation allows full remote control of the affected system, enabling attackers to execute commands, maintain persistence, and pivot to other systems.

Proof of Concept / Evidence

A relevant exploit was identified via ExploitDB and executed using the Metasploit Framework. This resulted in the establishment of a remote interactive session on the target system, confirming successful remote code execution.

Remediation

- Apply relevant security patches
- Remove or update vulnerable services
- Restrict exposure of externally accessible services

Finding F-007: Privilege Escalation to Root

Severity	CRITICAL	CVSS Score	10.0
Affected Host	172.20.10.2		
Port / Service	Local System		

Description

Following initial access, a local privilege escalation vulnerability was exploited to obtain root-level access on the system.

Risk / Business Impact

Root access provides complete control over the system, allowing modification of system files, installation of persistent backdoors, and unrestricted access to all data.

Proof of Concept / Evidence

Post-exploitation activities confirmed that elevated privileges were successfully obtained, granting full administrative (root) access to the system.

Remediation

- Apply system updates and patches
- Enforce least privilege principles
- Monitor and restrict privilege escalation paths

Finding F-008: Database Access via phpMyAdmin

Severity	HIGH	CVSS Score	7.5
Affected Host	172.20.10.2		
Port / Service	12380/tcp — HTTP (phpMyAdmin)		

Description

Database access was obtained through phpMyAdmin using compromised credentials, allowing direct interaction with backend database systems.

Risk / Business Impact

Exposure of database contents may lead to leakage of sensitive information, including user credentials and application data, potentially resulting in further compromise.

Proof of Concept / Evidence

Successful authentication to the phpMyAdmin interface allowed viewing and extraction of database contents, including user-related information and stored credentials.

Remediation

- Restrict access to phpMyAdmin
- Enforce strong authentication controls
- Limit database exposure to trusted networks

7. Remediation Roadmap

The following table provides a prioritized remediation roadmap based on the severity of identified vulnerabilities. Immediate attention should be given to Critical and High severity findings to reduce the overall risk exposure.

ID	Finding	Severity	SLA (Days)	Owner	Status
F-001	Anonymous FTP Access	HIGH	7 Days	Infrastructure	Open
F-002	SMB Share Exposure	HIGH	7 Days	Infrastructure	Open
F-003	Weak Credentials Compromise	CRITICAL	Immediate (24h)	Security / IT	Open
F-004	WordPress Admin Access	CRITICAL	Immediate (24h)	Web Admin	Open
F-005	Plugin Upload Code Execution	CRITICAL	Immediate (24h)	Web Admin	Open
F-006	Remote Code Execution (Exploit)	CRITICAL	Immediate (24h)	Security / IT	Open
F-007	Privilege Escalation	CRITICAL	Immediate (24h)	System Admin	Open
F-008	Database Access via phpMyAdmin	HIGH	7 Days	Database Admin	Open

8. Conclusion

The penetration test identified a total of 8 vulnerabilities across the assessed environment, including 5 Critical and 3 High severity findings. These vulnerabilities present significant risk to the confidentiality, integrity, and availability of the assessed systems.

The most critical risks arise from the combination of weak authentication mechanisms, insecure service configurations, and the ability to achieve remote code execution. These issues were successfully chained together to gain unauthorized access, execute arbitrary code, escalate privileges, and ultimately obtain full system control.

The assessment demonstrates how an attacker can move from initial access (via anonymous FTP and exposed SMB shares) to complete system compromise through credential abuse, application-level exploitation, and privilege escalation.

It is strongly recommended that all Critical and High severity findings be remediated within the defined timelines. Addressing these vulnerabilities will significantly reduce the overall attack surface and improve the security posture of the environment.

Tester Sign-off

Student Security Analyst	Reviewed By	Date
Ayisha Minha	Faculty Supervisor	April 2026